



Hardening perimetral y políticas de control de acceso

Cierre de Unidad 1 — antes del Parcial 1

Ing. Rodolfo Cañas Cervantes

Universidad de la Costa (CUC) · Ingeniería de Sistemas

Semana 5 · Periodo 2026-2 · Barranquilla, Colombia

4 bloques, 1 hilo conductor

No basta con filtrar: hay que endurecer y formalizar el acceso.

Hardening

reducir superficie de ataque

Checklist perimetral

5 pasos sistemáticos

Políticas de acceso

RBAC & ABAC · mínimo privilegio

Caso aplicado

Corporación Industrial del Caribe

Lo que ya vimos en S02 / S03 / S04 eran **piezas** de esto. Hoy les ponemos el nombre.

Lo que ya dominas — ahora con otro nombre

Lo que aprendiste en S02 / S03 / S04 ya era seguridad. Solo faltaba el paraguas.

S2

Reducir superficie

Regla mínima de firewall / NGFW. Bloquear por defecto y abrir solo lo necesario.

S3

Aislar por zonas

VLANs, subnetting, DMZ. Si algo se compromete, el daño no se propaga.

S4

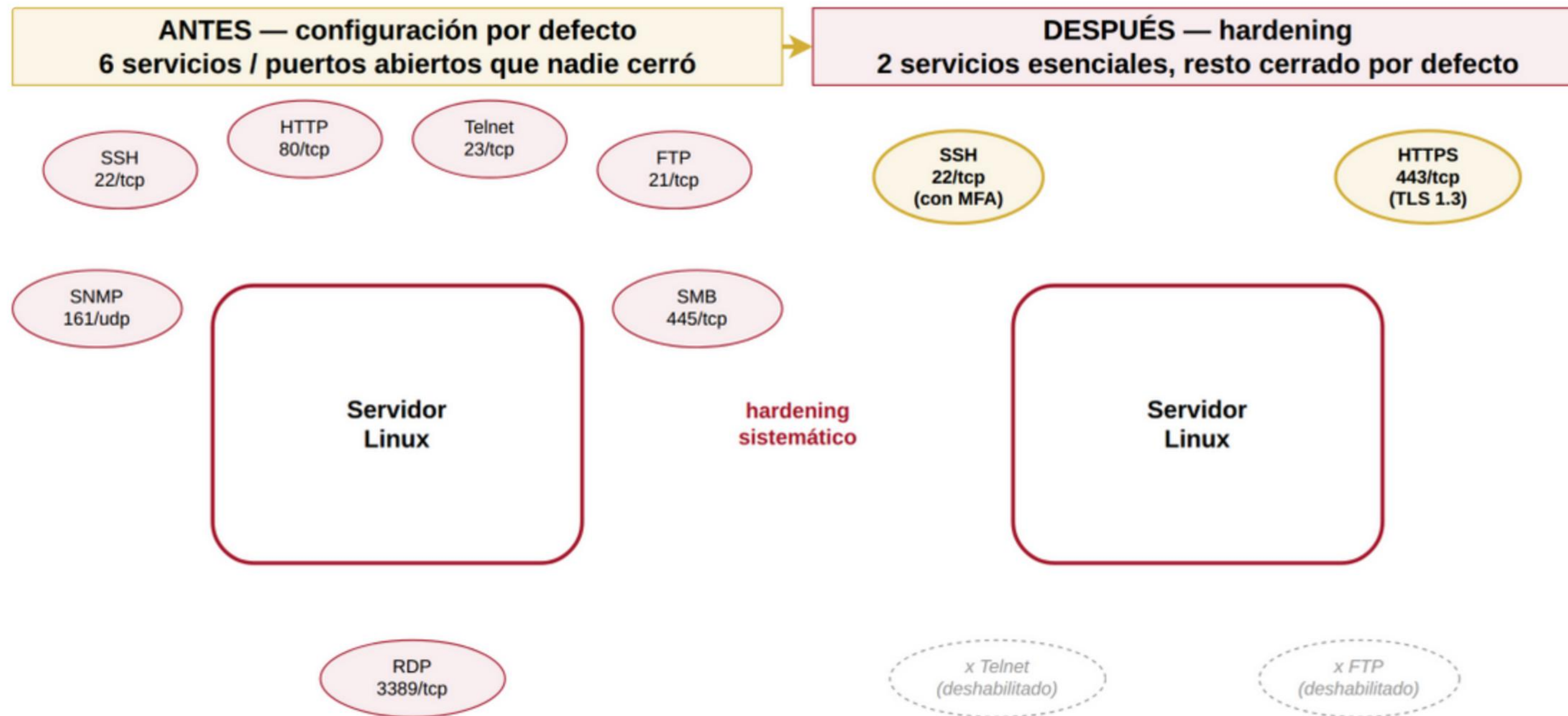
Filtrar + detectar

ufw con deny por defecto, IDS/IPS, Security Groups. Lo que ya pasa, lo vigilas.

Hardening sistemático es la actividad que ata las tres y las hace repetibles.

Hardening: cerrar puertas que la configuración por defecto dejó abiertas

Reducir superficie = cerrar servicios, puertos y cuentas que nadie usa.



CIS publica +100 **benchmarks** vendor-neutral sobre 300+ tecnologías — la reducción de superficie es de las medidas con mejor relación costo/beneficio.

Checklist de hardening perimetral · 5 pasos

El checklist no reemplaza al firewall de S04 — lo hace sistemático.

CHECKLIST DE HARDENING PERIMETRAL 5 pasos para reducir la superficie de ataque

OK

1. Deshabilitar servicios / puertos no esenciales

OK

2. Eliminar o rotar credenciales por defecto

OK

3. Aplicar el parche / CVE crítico pendiente

OK

4. Política por defecto DENY y abrir solo lo necesario

OK

5. Logging obligatorio de todo cambio de regla

De la regla a la política

Una regla de firewall dice qué IP y qué puerto. Una política dice quién y bajo qué condición.

REGLA DE FIREWALL
(estática)

origen IP

10.0.1.0/24

+

destino puerto

TCP 443

estática, no sabe quién es el usuario detrás del paquete

POLÍTICA DE ACCESO
(evaluada en cada solicitud)

usuario / rol

¿es Ana (rol: analista)? ¿es del depto de red?

+

recurso + condición

acceso al panel de gestión
solo en horario laboral + desde VPN

gobierna lo que el firewall ya no puede ver: quién es la persona detrás del paquete

Las políticas gobiernan lo que el firewall **ya no puede ver**: quién es la persona detrás del paquete.

RBAC vs ABAC · dos formas de decidir el acceso

El principio de mínimo privilegio es el hilo común — el modelo solo cambia cómo se aplica.

RBAC

Role-Based Access Control — permisos atados a un rol fijo (ej. *analista de red, soporte N1*).

Ventajas: simple de administrar y auditar, funciona bien con organigramas claros.

Coste: los roles se **multiplican** al crecer la organización — la matriz de roles explota.

ABAC

Attribute-Based Access Control — decide por atributos en tiempo real: usuario + recurso + hora + ubicación.

Ventajas: más granular y sensible al contexto (ej. "solo en horario laboral + desde VPN").

Coste: exige más diseño inicial — modelar bien los atributos no es trivial.

En la práctica muchas organizaciones combinan ambos: **RBAC como base**, ABAC para las decisiones contextuales.

Por qué falla en la práctica

El control existe. El problema es que no se aplica a tiempo.

37%

de las organizaciones tenían al menos una cuenta
admin de IaaS con MFA deshabilitado

8 meses

mediana para remediar la mitad de las fallas de
configuración de contraseñas/permisos

39%

de las brechas involucran abuso de credenciales en
algún punto de la cadena

Hardening y políticas de acceso son **baratos de definir, caros de posponer.**

Caso aplicado · Corporación Industrial del Caribe

La mesa de ayuda administra los firewalls de las 3 sedes con una sola cuenta compartida.

Escenario

Una sola cuenta admin compartida (mesa de ayuda TI) para administrar los firewalls de las 3 sedes de la empresa. **Sin MFA. Sin registro** de quién cambió qué regla. La contraseña es la misma desde 2023.

Pregunta para la clase

¿Qué **política de acceso** (RBAC o ABAC) y qué **2 ítems del checklist** de hardening cerrarían esto primero?

No se resuelve en la slide — queda para la vivencia en clase.

Lo que sigue · profundizar, no repetir

La Unidad 2 abre con identidad a fondo — el corazón de cualquier política de acceso.

S6

Repaso + Parcial 1

Cierre formal de Unidad 1. Cubre semanas 1–5.

S7

Identidad a fondo

MFA, mínimo privilegio, Zero Trust — el modelo RBAC/ABAC de hoy se profundiza acá.

S8

Monitoreo / SIEM

Una vez definidos los controles, hay que ver cómo se observan en operación.

Hoy cerramos **qué** asegurar. U2 abre **cómo se opera** el día a día.

Para la próxima

Parcial 1 · semana 6

Cubre **semanas 1 a 5** — hoy también entra.

Traer dudas

De **ufw** / Security Groups (S04) o de **segmentación** (S03), no solo de hoy.

El checklist de la slide 5 también se entrega como hoja de trabajo para el laboratorio.